

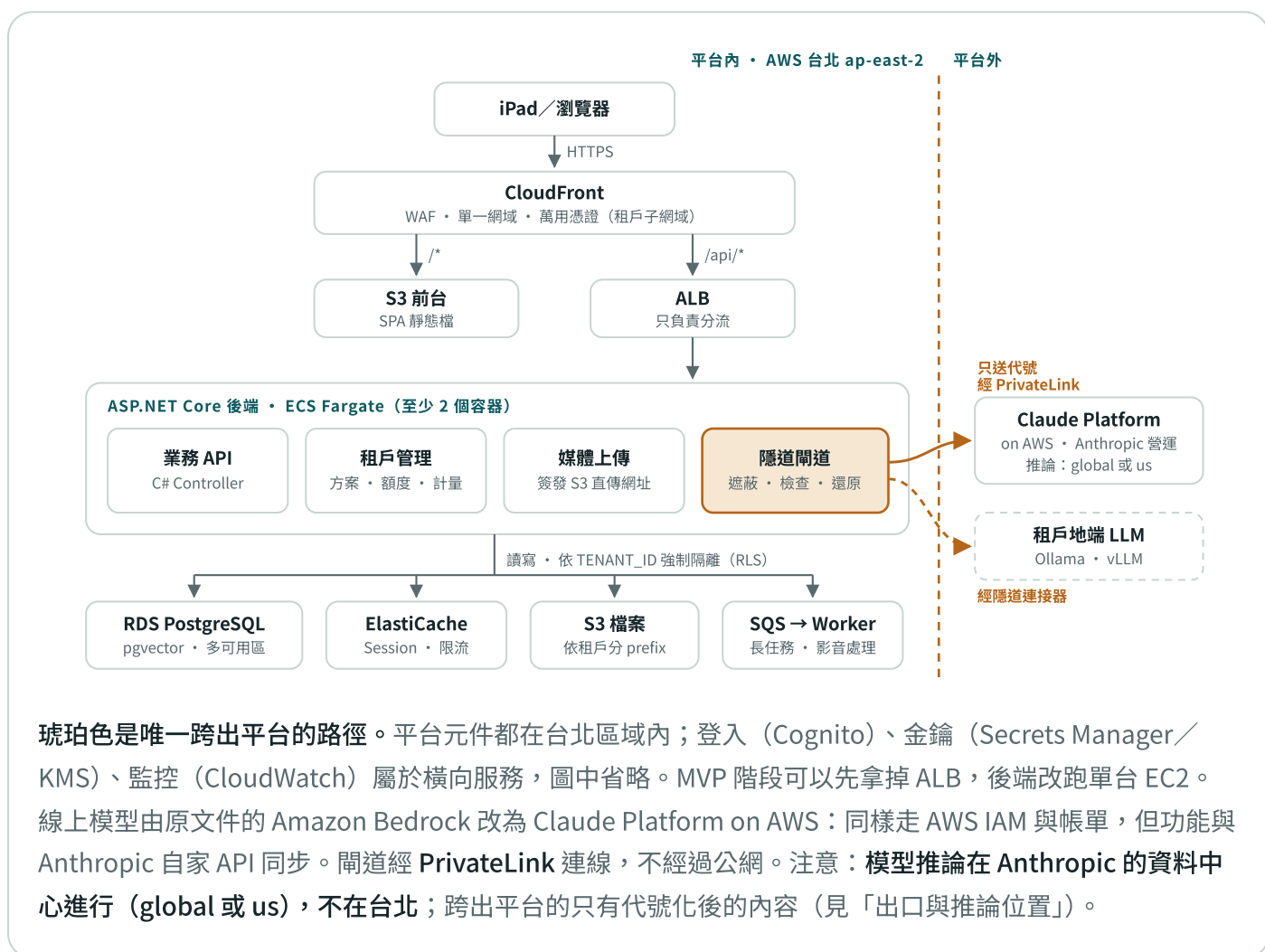
隱道 Veilway

所有 AI 請求都走同一條道：送出前在平台內把個資換成代號，回覆回來後再換回真名。外部模型從頭到尾只看得到代號。

v2 (2026-10-07)：出口改走 PrivateLink、補上推論位置的查證結果、檢查點處理規則，以及特殊合規租戶的建議。

全景：隱道在系統中的位置

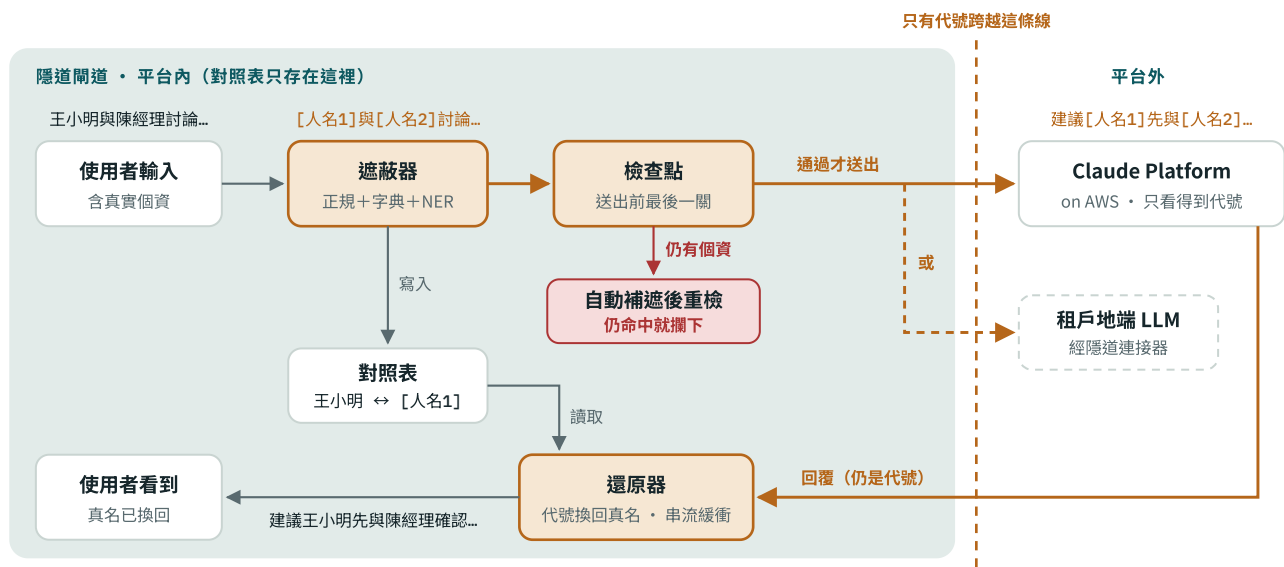
前台、業務 API、資料庫都是標準配置。整套架構跟一般 SaaS 不同的地方，在於後端唯一能連到平台外模型的出口，就是隱道閘道。



琥珀色是唯一跨出平台的路徑。平台元件都在台北區域內；登入 (Cognito)、金鑰 (Secrets Manager／KMS)、監控 (CloudWatch) 屬於橫向服務，圖中省略。MVP 階段可以先拿掉 ALB，後端改跑單台 EC2。線上模型由原文件的 Amazon Bedrock 改為 Claude Platform on AWS：同樣走 AWS IAM 與帳單，但功能與 Anthropic 自家 API 同步。閘道經 PrivateLink 連線，不經過公網。注意：模型推論在 Anthropic 的資料中心進行 (global 或 us)，不在台北；跨出平台的只有代號化後的內容 (見「出口與推論位置」)。

一次請求怎麼走過隱道

以文件中的例子示範：使用者輸入含有人名和地點的句子，Claude 收到的只有代號，回覆也是代號，最後由平台換回真名。



對照表從不離開平台，所以外部模型就算保留了請求內容，也無法把代號對回真人。每次實際送出的遮蔽後內容，以及實際推論位置 (usage.inference_geo)，會寫進 AI_REQUEST_LOG 作為稽核紀錄。影像、錄音和間接識別資訊的遮蔽方式還待設計。

隱道的元件

位置	中文名	英文名	做法
後端內的 AI Gateway	隱道閘道	Veilway Gateway	統一介面 (IChatClient)，遮蔽、檢查、還原、計量各為一層 DelegatingChatClient；唯一能連到平台外模型的出口
去程第一步	遮蔽器	Veil Masker	三層：① 正規表示式 (身分證、電話、Email、卡號、統編) ② 租戶字典 (客戶名單、員工名冊) ③ CPU 可跑的繁中 NER (人名、地址、公司名)；另做別名展開：王小明 → 小明、王先生
平台資料庫	對照表	Veil Map	真名與代號的對應，只存在平台內 (RDS，以租戶的 KMS key 加密)。預設每個對話一張並設 TTL；RAG 才用租戶範圍；絕不跨租戶
跨越邊界前	檢查點	Veil Check	送出前比對對照表原值、重跑正規表示式、比對租戶字典；處理規則見下一節
回程	還原器	Unveiler	讀取對照表，把回覆中的代號換回真名；容許模型改寫代號格式，串流時用緩衝區處理被切開的代號
通往租戶機房	隱道連接器	Veilway Connector	接 Ollama/vLLM 等 OpenAI 相容端點，切換只需改 endpoint；有特殊合規要求的租戶走這條

檢查點：攔下之後怎麼辦

檢查點掃描「準備送出的最終文字」，檢查三件事：對照表裡已登記的原值又出現了、格式固定的個資漏網、租戶字典裡的名字出現了。

情況	處理
對照表裡的原值沒換掉	自動補遮後重送，使用者不會感覺到
高信心命中（身分證、卡號）	自動補遮；補遮後仍命中就 fail-closed ，拒絕送出
低信心命中（如「林立」）	依租戶政策：嚴格的租戶直接拒絕；一般租戶讓使用者勾選「這不是個資」後送出，並記下這次放行
檢查點故障或逾時	一律 fail-closed ，不能因為檢查服務壞了就放行

限制：NER 第一次沒認出來的名字，檢查點多半也認不出來。檢查點防的是程式出錯，不是第二層 NER。每次攔截都寫入稽核紀錄（類型與處理方式），但**不記錄命中的原文**。

出口與推論位置

以下依 Anthropic 官方文件查證（2026-10）。

項目	結果
VPC endpoint	支援 AWS PrivateLink。閘道經 VPC endpoint 連線，endpoint 的 security group 與 policy 只允許閘道，呼叫權限只授權給閘道的 IAM role
區域	所有 AWS 商用區域皆可用；workspace 建在台北區域，只能從台北端點存取
推論位置	inference_geo 只有 global（預設，全球任一 Anthropic 資料中心）與 us（只在美國，價格 1.1 倍）； 沒有台灣或亞太選項
AWS 區域的作用	只決定端點與 IAM、CloudTrail、帳單的範圍， 不決定推論在哪裡
資料保存位置	不可設定，目前為 us
資料處理者	Anthropic；保留政策同第一方 API，零資料保留（ZDR）需另外申請

結論：端點在台北，推論與保存在境外。這正是隱道要解決的問題：出境的只有代號，對照表留在台北。對外說法統一為「平台在台灣，只有代號化後的內容出境」，不說「資料都在台灣」。代號化屬於假名化，仍算個人資料，服務條款與租戶合約需揭露推論位置與資料處理者。

有特殊合規要求的租戶：建議自建地端 AI

租戶若要求資料（即使已代號化）不得出境、推論必須在特定地點或處理者的設施內進行，或受主管機關對委外與跨境傳輸的限制（例如金融、醫療、公部門），平台不提供境外模型，而是建議租戶在自己的機房架設地端 AI，平台經隱道連接器接過去。

為什麼這樣建議

- 1. **只有地端能完全做到資料不出境**。推論位置只有 global 與 us，沒有台灣選項；對最嚴格的租戶，代號出境本身就可能不被接受。
- 2. **不涉及第三方資料處理者**。地端由租戶自己營運，不需另簽資料處理協議或評估跨境傳輸。
- 3. **不必另外維護第二條雲端路徑**。改走 Bedrock 也是選項，但要多維護一套模型 ID 與功能差異，而且仍在租戶的控制之外。
- 4. **架構已經預留**。隱道連接器只需改 endpoint，依路由政策導向地端，業務程式碼不必修改。
- 5. **回答品質可以更好**。模型在租戶機房時，可依租戶政策不做遮蔽，模型看得到完整上下文。

取捨（要先講清楚）：地端模型能力通常不如 Claude；GPU、維運與更新由租戶負責；平台只保證連接器與路由的正確性。

建置三階段

階段	內容	完成時能做到
1 • 骨架	VPC、IaC、CI/CD、CloudFront+WAF、S3 前台、ALB、C# API、Cognito、RDS 基本資料表（含 RLS）	能登入，前台呼叫 API，依租戶讀寫資料
2 • 隱道	隱道開道、Claude Platform on AWS（PrivateLink）、對照表／對話／稽核／計量存 RDS、Ollama 開發用	能多輪對話，外部只看得到店號
3 • 檔案與非同步	S3 上傳、SQS+Worker、文件解析與遮蔽、影音處理；可選：RAG、Batch、租戶地端連接器	上傳文件請 AI 分析，耗時工作不卡住 API

依據「AI-前后台架構總結」（2026-10-06）繪製；線上模型已改為 Claude Platform on AWS，並依 Anthropic 官方文件查證出口與推論位置（2026-10-07）。參考：[Claude Platform on AWS](#)、[Data residency](#)。